

UVOD U VULNERABILITY MANAGEMENT

Vežbe 1

Upravljanje Ranljivostima (Vulnerability Management)



Proces identifikacije sigurnosnih slabosti i ranjivosti u softveru, izveštavanje o njima i njihovo otklanjanje kako bi se smanjio rizik i uticaj sajber napada.



Cilj: Smanjiti **attack surface** (površinu napada) – broj potencijalnih sigurnosnih ranjivosti koje zlonamerni akteri mogu iskoristiti za napad na organizaciju.

Ključni koraci u procesu:

Identifikacija:

- Korišćenje **vulnerability skenera**, manuelnih tehnika i metoda otkrivanja (na serverima, desktop računarima, mobilnim i IoT uređajima...).
- Vrednovanje ranjivosti na osnovu različitih faktora (**CVSS scores**).

Izveštavanje:

- Prijava identifikovanih ranjivosti relevantnim učesnicima (npr. vlasnicima sistema ili seniorima) radi preduzimanja akcija.

Proces Upravljanja Ranljivostima (Nastavak)

Sanacija (Remediation):

- Otklanjanje sigurnosnih ranjivosti od strane security inženjera.
- Metode sanacije uključuju: security patches, rekonfiguracije, ili primenu kontrola za ublažavanje ranjivosti (mitigating controls).

Ponovna Procena (Reassessment):

- Provera kroz ponovno skeniranje ili manuelnu inspekciju da li su ranjivosti uspešno otklonjene.

Sve ovo navedeno je **ciklični** proces:

- Sistemi se redovno skeniraju, naročito posle većih promena.
- Brza identifikacija i otklanjanje ranjivosti smanjuje šanse da ih zlonamerni akteri iskoriste.

Na čemu ćemo se igrati?

Metasploitable 3 je virtuelna mašina sa namerno ugrađenim ranjivostima, kreirana od strane kompanije Rapid7.

Metasploitable 3 je realističnija u poređenju sa prethodnim verzijama, sa ciljem simulacije ranjivosti u stvarnim okruženjima, sa fokusom na **vulnerability scanning**.

Vežba 1:

```
sudo docker run -h victim -it --rm --name metasploitable2 tleemcjr/metasploitable2
```



Koliko TCP portova je OTVORENO na mašini? (nmap –sT)



Koliko UDP portova je OTVORENO na mašini? (nmap -sU)



Na kom portu se pokreće Metasploitable Root Shell? (nmap -sV)



Na kom nestandardnom portu radi FTP? (NIJE port 21) (nmap -sT)



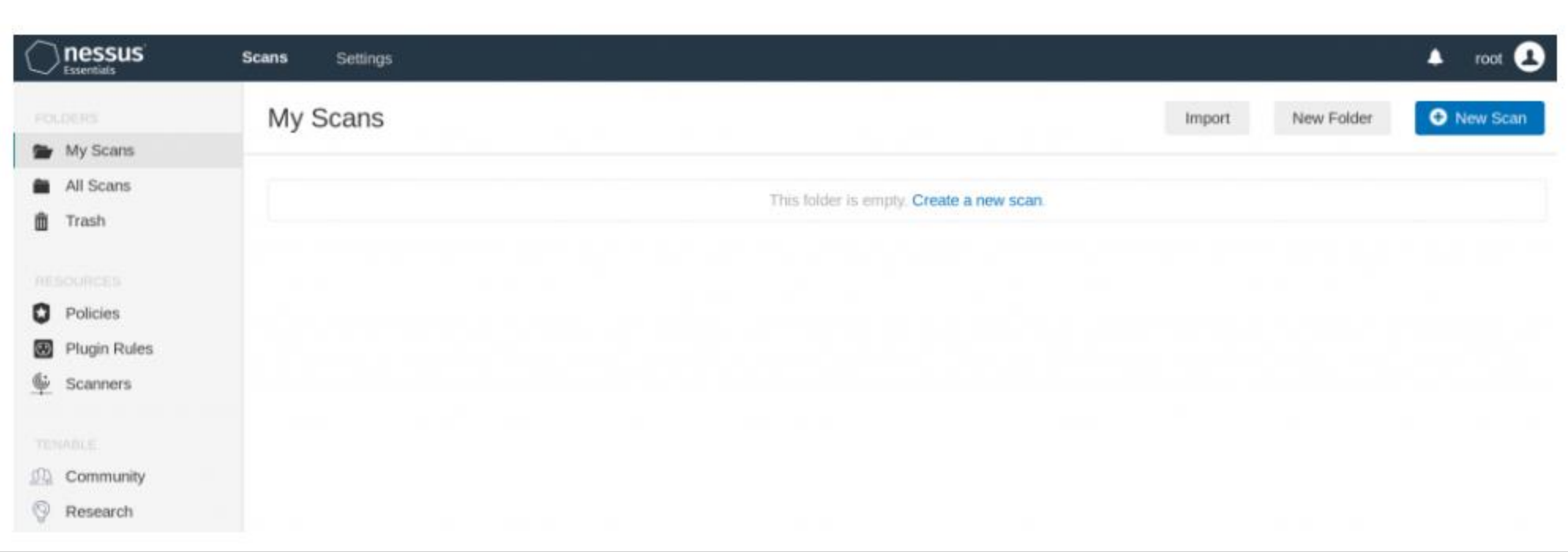
Koja verzija FTP-a radi na nestandardnom portu? (nmap -sV)



Nessus

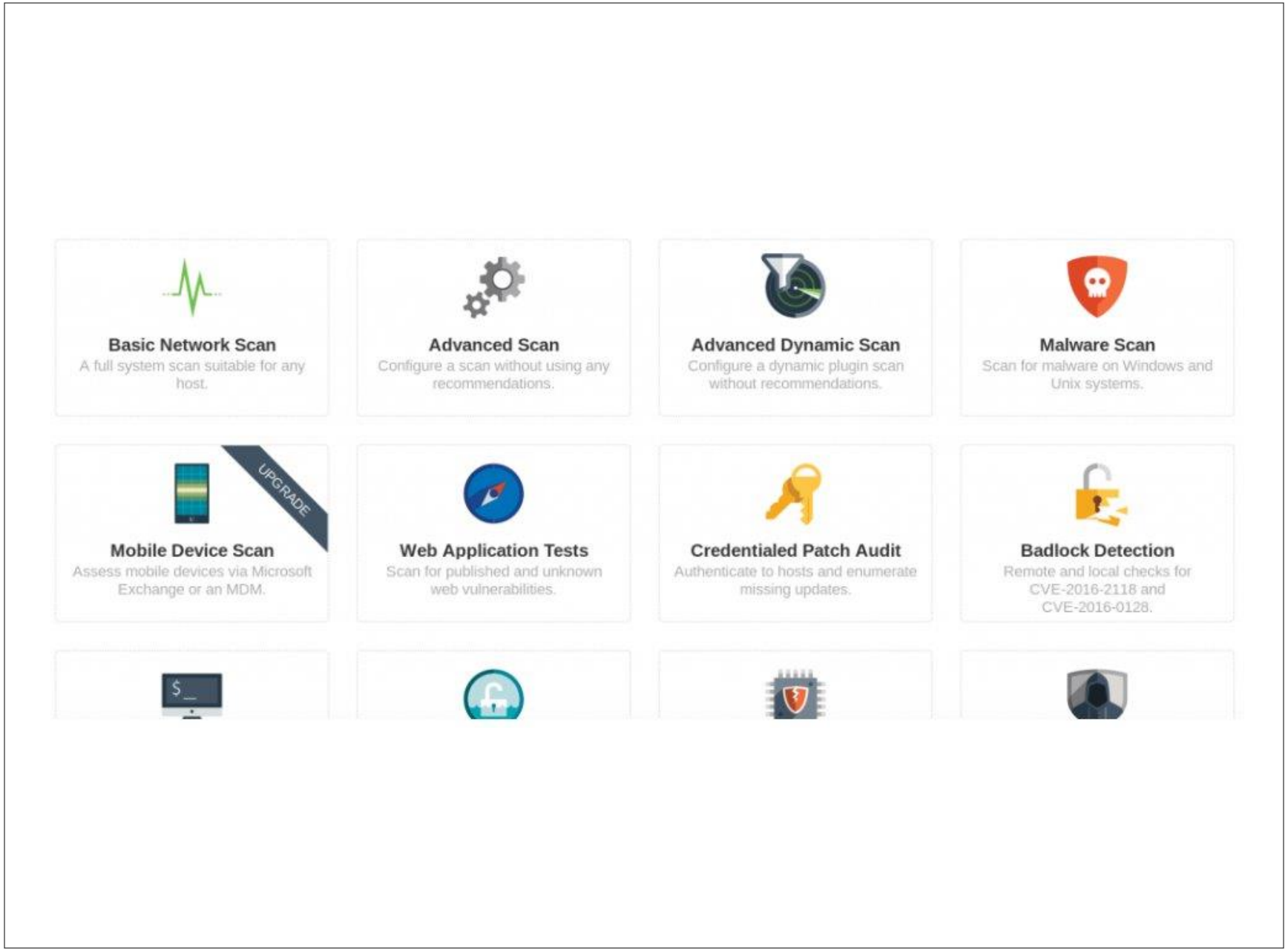
- **Nessus** je jedan od najpopularnijih alata za skeniranje ranjivosti, razvijen od strane **Tenable, Inc.**.
- Namenjen je za identifikaciju sigurnosnih slabosti (**security weakness**), **misconfigurations**-a i potencijalno opasnih softverskih propusta (**security vulnerability**) na uređajima u mreži.

- Ovim linkom do education licence 😉 : https://www.tenable.com/tenable-for-education/nessus-essentials?edu=true



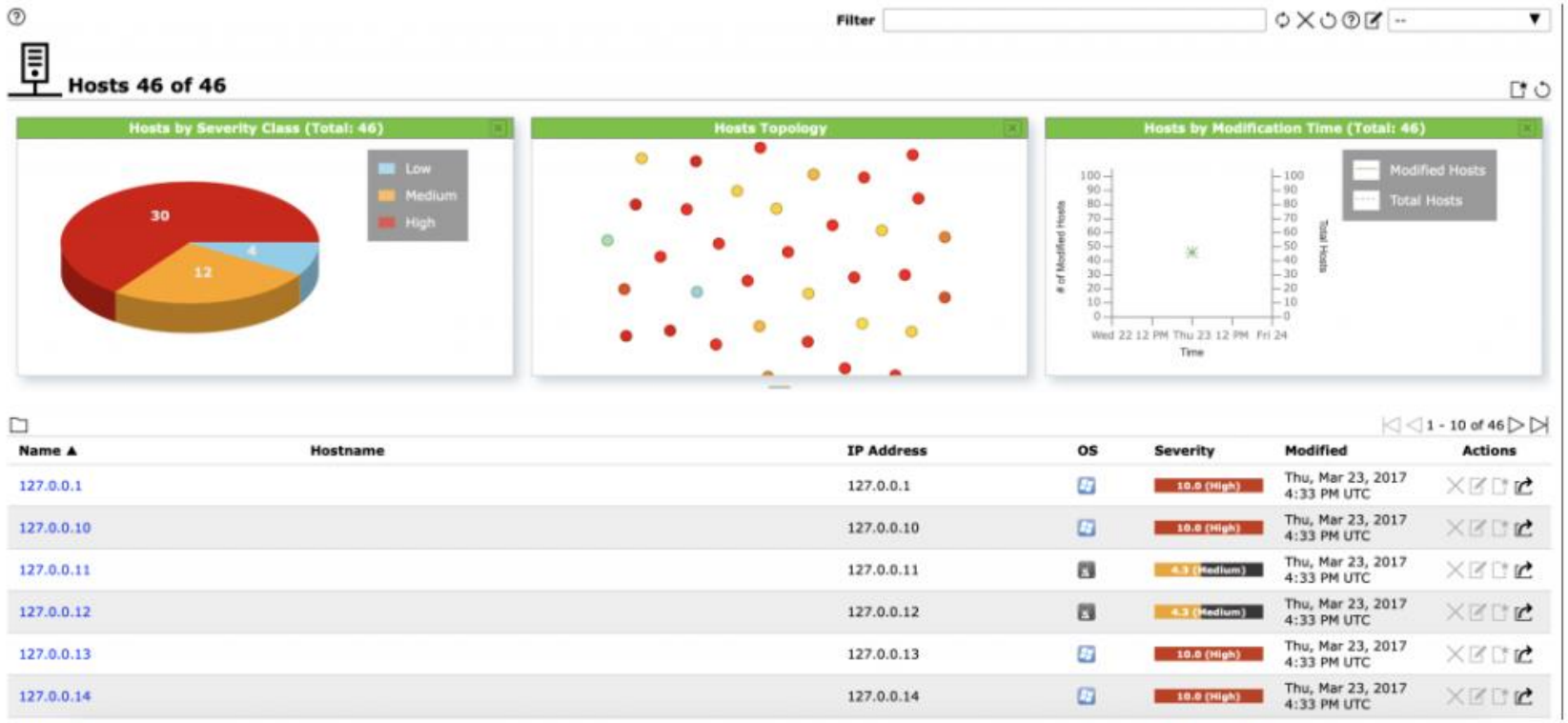
- Nessus GUI sadrži nekoliko ključnih sekcija za upravljanje skeniranjem ranjivosti. **"My Scans"** prikazuje skeniranja koja je pokrenuo trenutni korisnik, dok **"All Scans"** obuhvata skeniranja svih korisnika u organizaciji. **Policies** zahteva target i polisu, I prikazuje nam stepen usklađenosti sa nekom polisom ili sa standardom. **Plugin Rules** omogućavaju preciznije podešavanje skeniranja odabirom specifičnih dodataka za otkrivanje ranjivosti. **Scanners** upravlja pokrenutim scan-ovima koji vrše skeniranje različitih mrežnih segmenata.

- Različiti tipovi skeniranja...
- Da li znate šta koji radi? :)



OpenVAC

- Alternativa Nessus-u, stariji fork ovog alata koji se nezavisno razvijao.
- Postoji free verzija: https://www.greenbone.net/en/testnow/



Common Vulnerabilities and Exposures

- CVE (Common Vulnerabilities and Exposures) standardizuje nazive za javno poznate ranjivosti, slično kao što domeni olakšavaju pristup sajtovima.
- CVE-2019-0708 odnosi se na BlueKeep ranjivost u RDP protokolu
- Ovakav zapis omogućava lakšu identifikaciju i razmenu informacija među alatima i bazama podataka.
- CVE standard osigurava MITRE, a svaki unos sadrži identifikacioni broj, opis i barem jednu javnu referencu.
- Sajtovi kao **CVEDetails.com** ili NVD pružaju detaljne informacije i omogućavaju pretragu specifičnih CVE ranjivosti.





Vežbicaaa :)

- Dobili smo izveštaj o novoj ranjivosti koja targetira starije verzije Adobe Acrobat i Reader softvera. Poruku smo dobili preko TweetDeck-a koji nam služi kao monitoring platforma.

- Znamo da većina endpointa u našoj organizaciji ima instaliranu verziju 2019.012.20035, te da smo ranjivi. Moramo da istražimo o kakvoj je ranjivosti konkretno reč, kao i da odredimo ozbiljnost (**severity**) i da li možemo nešto odmah da uradimo ili ne.



Common Vulnerability Scoring System

- Pomaže nam da rangiramo ranjivosti putem metrike zasnovane na njenim atributima.
- Sam broj 8.8 može da nam ukaže da je ova ranjivost veoma ozbiljna ali mnogo je bolje da razumemo i zašto je to tako. Tu nam pomaže vektor!

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

- CVSS:3.0 = Ova ocena je generisana koristeći **CVSS 3.0** (za razliku od verzije 2.0)
- AV = **Attack Vector: Network** (Eksploatacija se može dogoditi preko mreže, kao što je internet)
- AC = **Attack Complexity: Low** (Ovaj napad je lako izvesti i ne zahteva mnogo tehničkog znanja)
- PR = **Privileges Required: None** (Napadaču nisu potrebni specifični privilegiji ili nalog za uspešnu eksploataciju)
- UI = **User Interaction: Required** (Eksploatacija zahteva interakciju legitimnog korisnika, poput klika ili otvaranja maliciozne datoteke)
- S = **Scope: Unchanged** (Opseg ranjivosti nije promenjen)
- C = **Confidentiality Impact: High** (Narušena je poverljivost, napadač dobija pristup informacijama koje bi trebale biti zaštićene)
- I = **Integrity Impact: High** (Narušen je integritet, napadač može menjati fajlove ili podatke)
- A = **Availability Impact: High** (Narušena je dostupnost, napadač može ograničiti legitimni pristup sistemu)

Zadaci za KT1

1. Podelite se u tročlane timove
2. Svaki tim mora da podigne bar jednu instancu Metasploitable3 mašine na koji god način želi (bilo koja VM, Docker...)
3. Svaki član tima treba da instalira Nessus ili OpenVAC (iskreno, bolje Nessus)
4. Svaki člatima treba da izvrši skeniranje ranjive mašine i da napravi detaljan izveštaj za 1 vulnerability

P.S. - Šablon za izveštaj se nalazi na Canvas-u.